Universidade Federal Rural do Semi-Árido – UFERSA
Departamento de Computação – DC

Certificados Digitais

Segurança Computacional

Roteiro

- Motivação.
- Certificados digitais.
- Modelo PKI.
- Certificação e revogação.

Motivação

- Cenário didático: *como Alice sabe se a chave pública que ela obteve é, realmente, de Bob?*
  - Sequência de bits não permite identificação direta de Bob.
  - Usuários maliciosos podem tentar se passar por Bob.
- Então, a identificação **confiável** do dono da chave pública é fundamental para a criptografia assimétrica e assinatura digital.
- É necessária uma estrutura complementar para fazer a identificação.

Certificados digitais

- Um certificado digital é como uma identidade eletrônica segura.
  - Ele liga matematicamente uma chave pública a uma pessoa, empresa, servidor ou sistema, garantindo que essa chave realmente pertence àquela entidade.
- Trata-se de um documento digital assinado, contendo:
  - Identidade do dono do certificado (nome, e-mail, URL, IP e mais informações que permitam identificação única).
    - Certificado pode ser de um usuário, um sistema computacional, software ou partes dele que precisem de identificação única.
  - Chave pública do dono do certificado.
  - Identificação de quem emitiu/assinou o certificado.
  - Uma ou mais assinaturas digitais do conteúdo, emitidas por entidades que os usuários do certificado considerem confiáveis.

Certificados digitais

- O certificado de maior aceitação hoje na Internet é o descrito pelo X.509.
  - Recomendação do ITU-T *(International Telecommunication Union)*.
  - Fazem parte das Recomendações X.500 que definem um serviço de diretório.
    - Servidor ou conjunto de servidores distribuídos que mantém um banco de dados com informações sobre usuários.
  - X.509 define uma estrutura para serviços de autenticação pelo diretório X.500 aos seus usuários.
- Outro certificado bastante difundido é o PGP *(Pretty Good Privacy)*.

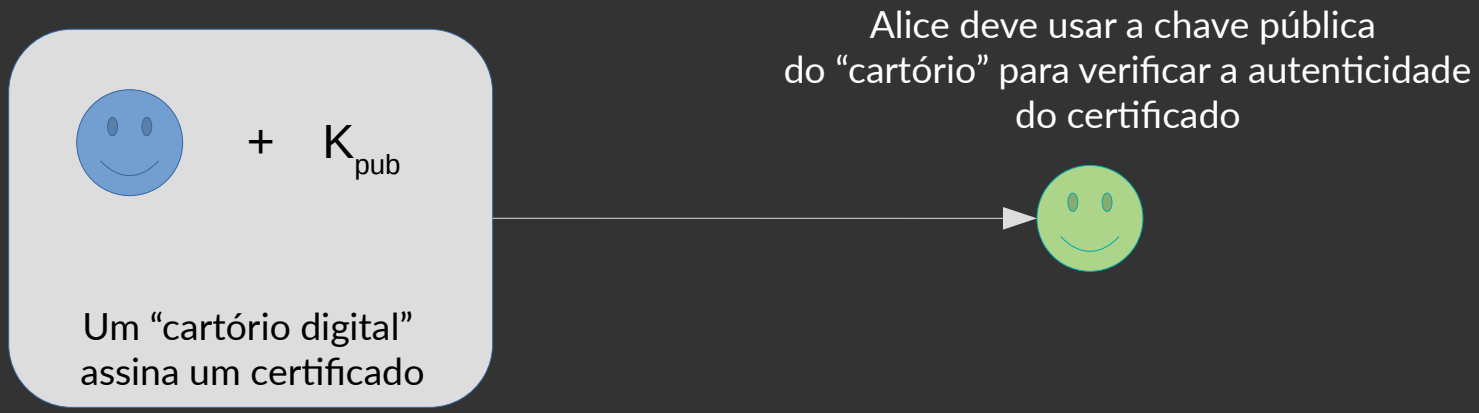
Certificados digitais

- Outro certificado bastante difundido é o PGP *(Pretty Good Privacy)*.
  - Certificados digitais tradicionais (como o padrão X.509, usado em sites HTTPS), dependem de uma Autoridade Certificadora (AC) centralizada.
  - PGP funciona sob um modelo descentralizado conhecido como Teia de Confiança *(Web of Trust)*.
    - Os próprios usuários atestam a identidade uns dos outros com algoritmos assimétricos.
    - Foco: Proteção de e-mails, arquivos pessoais e assinaturas de desenvolvedores.
    - Emissão: Criado de forma livre e gratuita pelo próprio usuário.

Certificados digitais: estrutura X.509

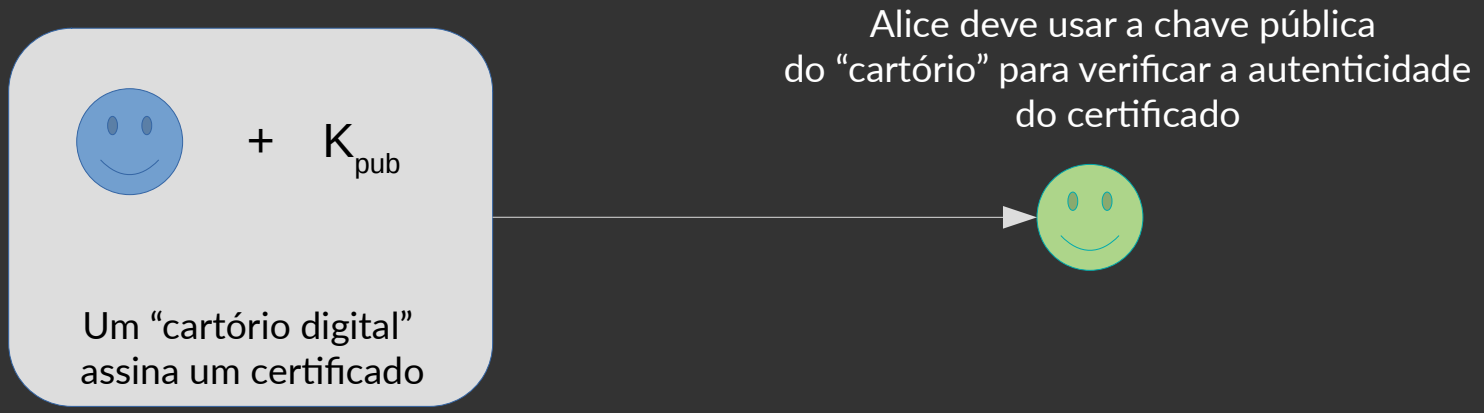
- Certificados digitais são gerados por alguma Autoridade Certificadora confiável.
  - Cada certificado digital contém a chave pública de um usuário e é assinado com a chave privada de uma Autoridade Certificadora Confiável.
  - X.509 recomenda o uso do RSA e exige o uso de uma função hash (sem ditar um algoritmo específico).
  - X.509 é popular:
    - IP Security (IPSec), SSL/TLS e SET.

Certificados digitais



Certificados digitais

Quem certifica o “cartório digital”?



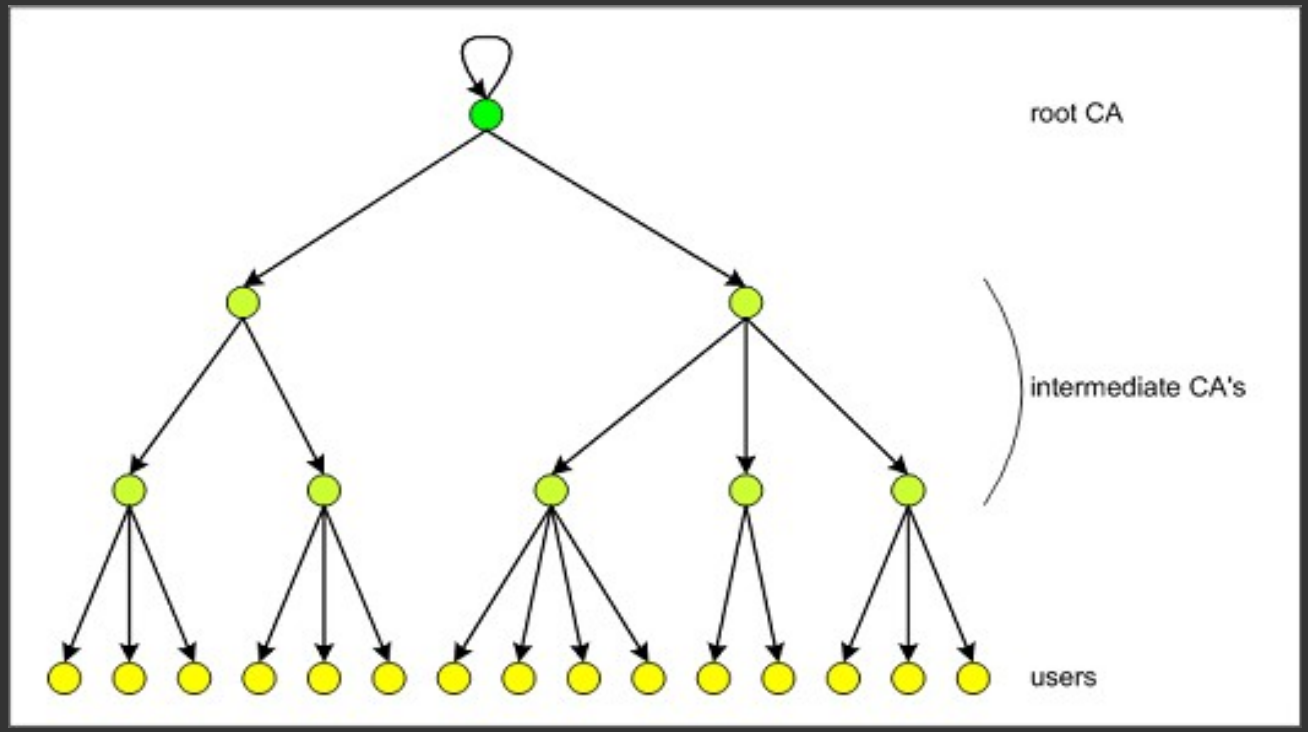
Modelo PKI – *Public Key Infrastructure*

- Certificado contém chave pública de Bob assinada por uma **Autoridade Certificadora - AC (“cartório digital”)**.
  - Parte-se da premissa de que a chave pública da AC é conhecida.
  - Geralmente, certificados das AC’s são pré-instalados em sistemas operacionais ou navegadores Web, por exemplo.
    - Contém os certificados de chaves públicas que as entidades desenvolvedores confiam.
  - Podem ser instalados por usuários?
    - ~~Não~~ Pode, mas com cuidado.

Modelo PKI – *Public Key Infrastructure*

- Traduzindo: modelo **ICP (Infraestrutura de Chaves Públicas)**.
  - Certificado de uma AC é assinado por outra AC mais confiável.
    - Estrutura hierárquica de certificação.
    - AC raiz assina certificados de outras AC's, que assinam de outras...
    - Até chegar em certificados de servidores, usuários e outras entidades.
  - Chaves mais próximas da raiz são mais protegidas.
  - AC's são dedicadas a vários fins.

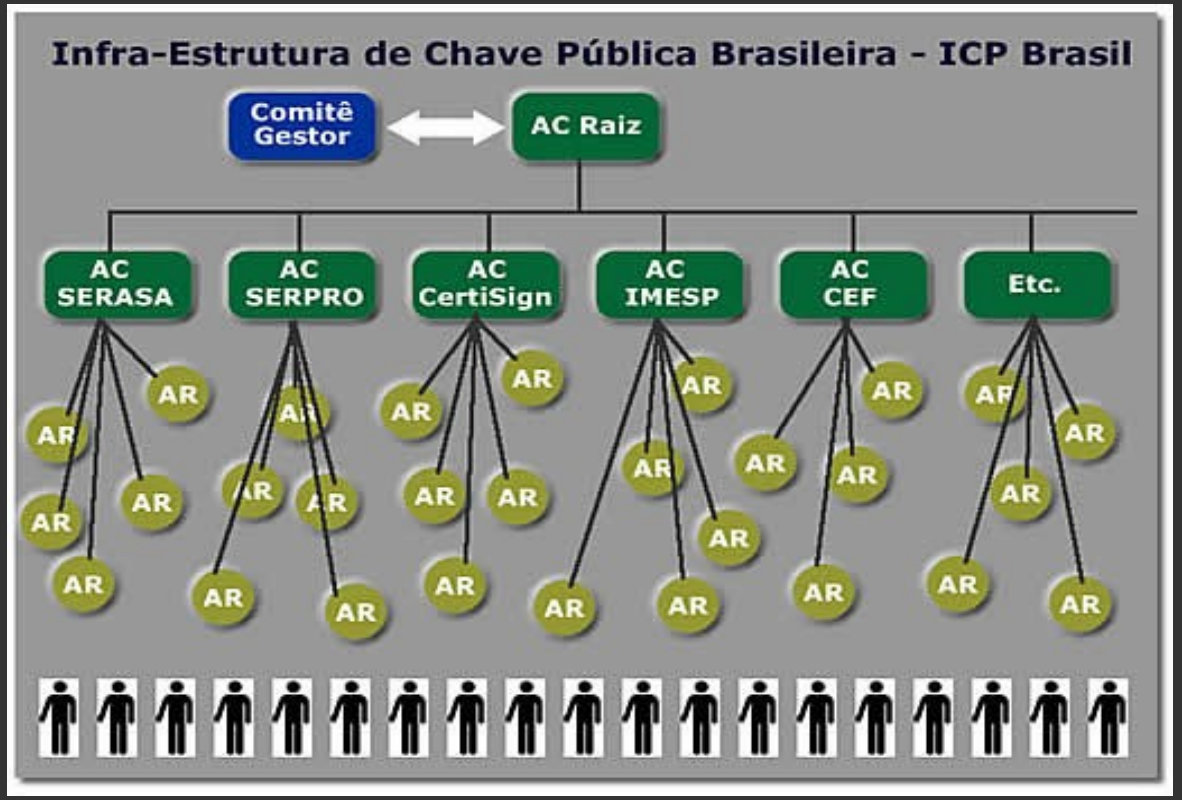
Modelo PKI – *Public Key Infrastructure*



Modelo PKI – *Public Key Infrastructure*

- Mais formal:
  - Especificação atualizada na RFC 6818.
  - Compreende o conjunto de hardware, software, pessoas, políticas e procedimentos necessários para criar, gerenciar, armazenar, distribuir e revogar certificados digitais com base na criptografia assimétrica.
  - Define o que é preciso para desenvolver uma PKI, permitindo a aquisição segura, conveniente e eficiente de chaves públicas.

ICP Brasil (diagrama simplificado)



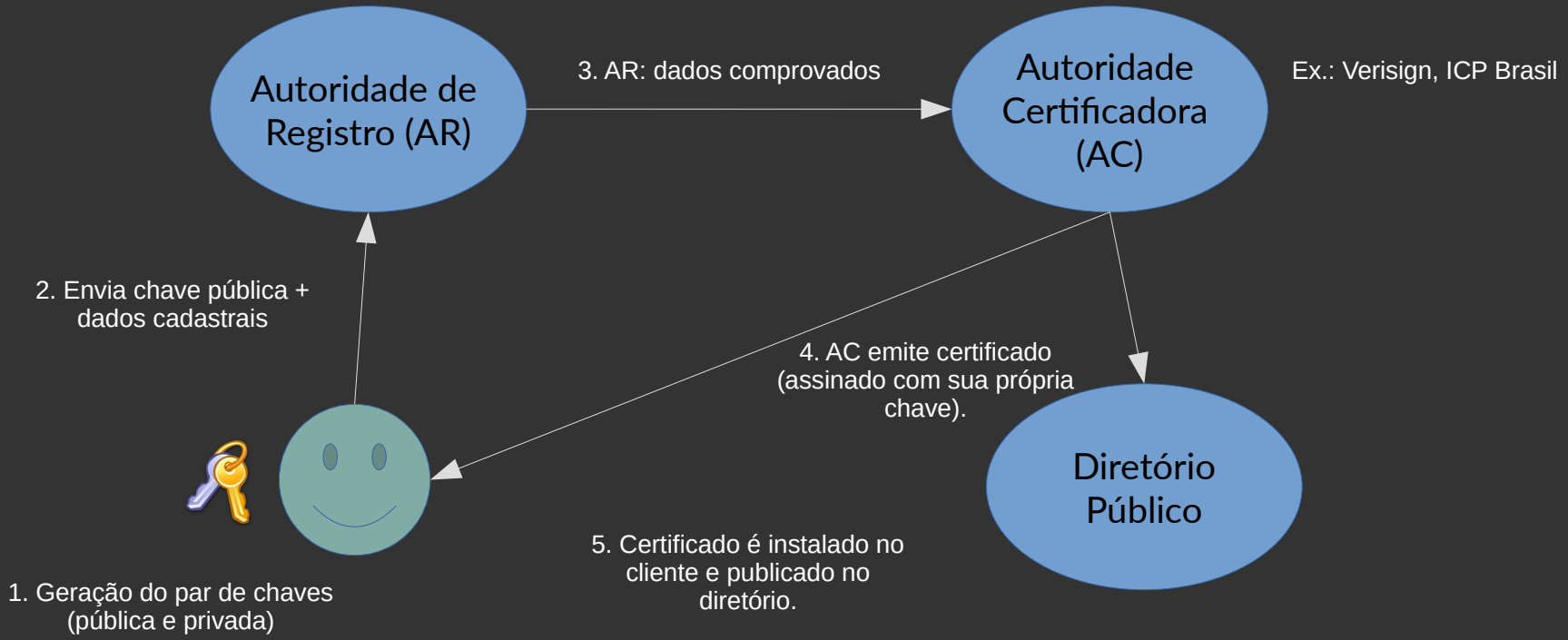
Processo de certificação

- As AC's atribuem a etapa de verificação de identidades a entidades de registro.
  - Chamadas de **Autoridades de Registro (AR)**.
    - Interface entre um usuário e uma AC.
    - Responsável por conferir as informações do usuário (entidade) e enviar a requisição do certificado para a AC (cara crachá).
      - Entidades apresentam suas chaves públicas e demonstram suas identidades (meios extra-criptográficos).
      - Dados a serem comprovados dependem da legislação vigente e políticas da AR.
      - Exemplo: provar propriedade sobre software ou um domínio onde deseja ter um site.

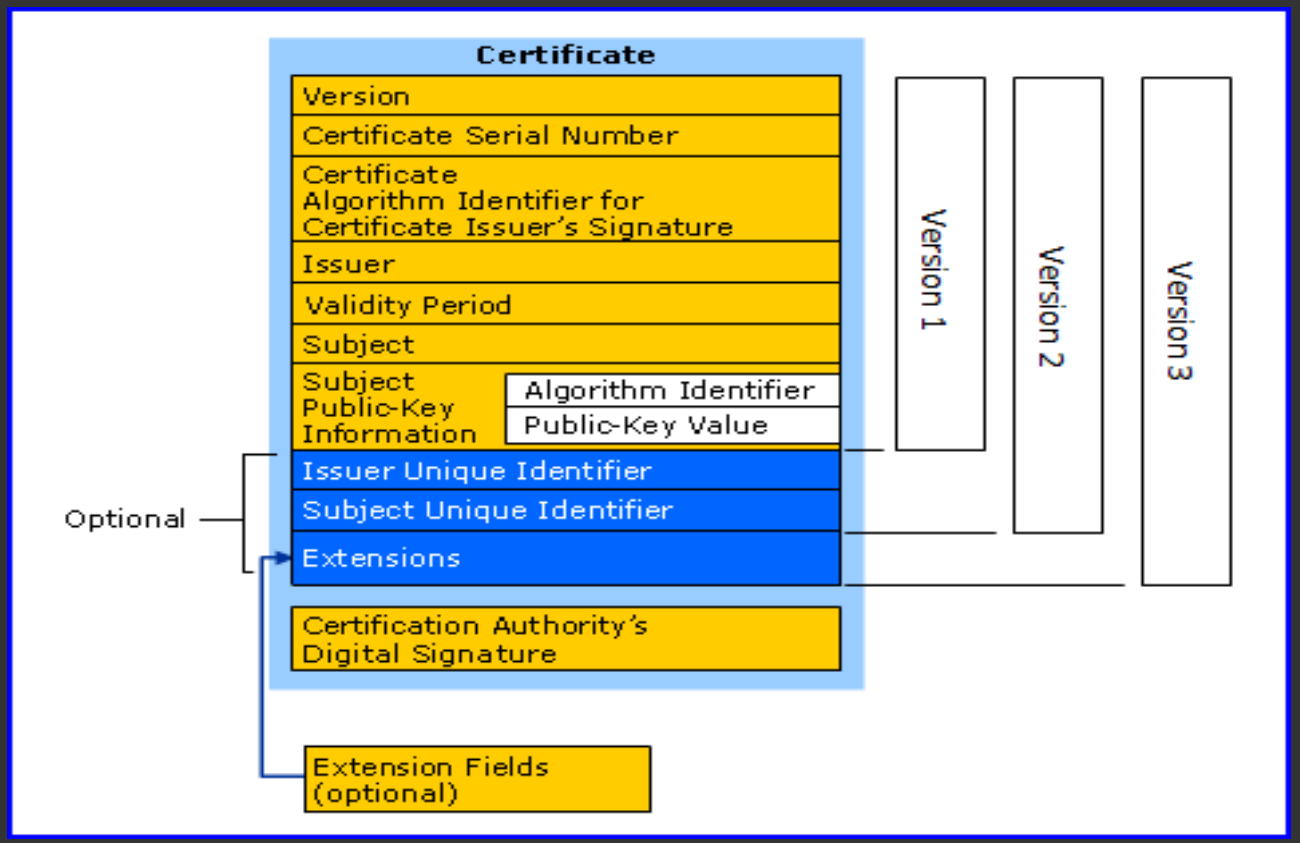
Processo de certificação

- Mas, o que são AC's?
  - Responsável pela geração, renovação, revogação de certificados digitais e emissão da **lista de certificados revogados (LCR)**, além das regras de publicação dos certificados digitais e LCR.
  - A AC pode ser uma empresa, organização ou indivíduo, público ou privado.
    - Recebe a requisição de certificado digital, assinada pela AR, confere a assinatura digital da AR e emite o certificado digital para o usuário final.

Processo de certificação



Exemplo de certificado X.509



Exemplo na prática

- Ao acessar: https://www.sistema.com.br.
  - O navegador:
    - Recebe: O site https://www.sistema.com.br envia seu certificado (emitido por DigiCert ou ICP-Brasil).
    - Valida: O navegador checa a assinatura digital da Autoridade Certificadora (AC).
    - Confere: O software garante que o nome no certificado é exatamente sistema.com.br.
    - Conecta: Se tudo bater, a chave verde se ativa e a conexão SSL/TLS é criada.
  - Isso garante:
    - Autenticidade: o site é realmente o do Sistema;
    - Confidencialidade: os dados são criptografados;
    - Integridade: a comunicação não foi alterada no caminho.

Exemplo na prática

- Ao acessar: https://www.gov.br.
  - Servidor envia: Certificado do site (www.gov.br).
  - Navegador verifica:
    - Certificado do site é assinado por Autoridade Intermediária (SERPRO).
    - Intermediária é assinada por Autoridade Raiz Brasileira (ICP-Brasil).
    - ICP-Brasil está instalada no navegador (confiança automática).
  - Conexão segura estabelecida.

Revogação de certificados

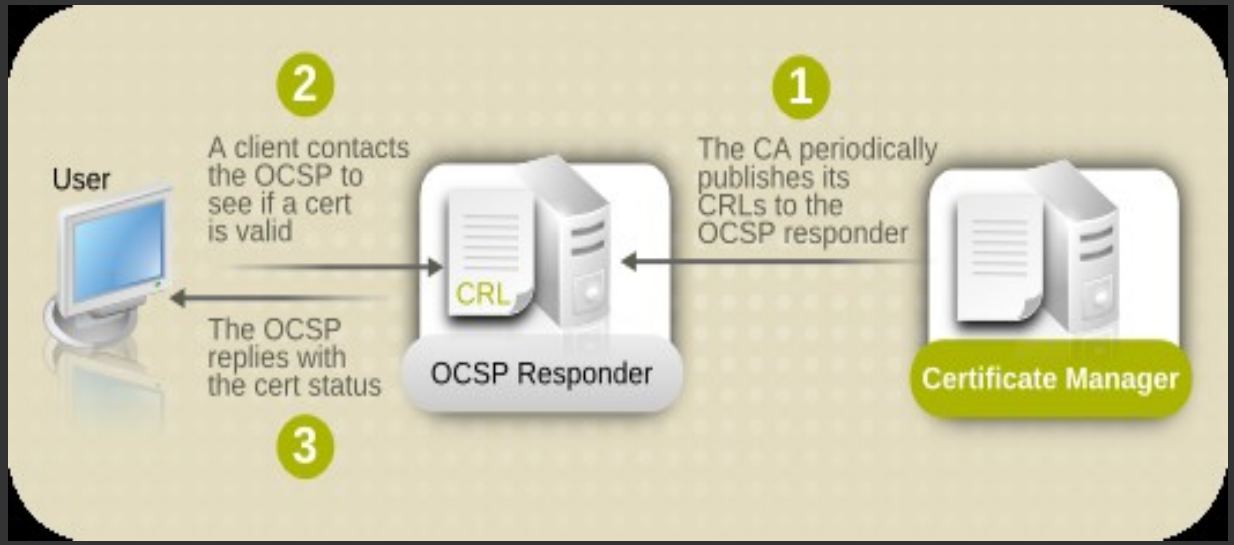
- Cada certificado digital possui um período de validade.
- Há situações em que é possível revogar um certificado, antes que ele expire.
  - A K_{PRI} do usuário tornou-se comprometida.
  - O uso não é mais certificado pela AC.
  - O certificado da AC tornou-se comprometido.
- Cada AC precisa manter uma Lista dos Certificados Revogados (LCR), porém não expirados, emitidos por ela.

Processo de revogação

- A AC, ao receber e analisar o pedido, adiciona o número de série do certificado à LCR.
- AC publica a LCR.
  - As LCR's são públicas e podem ser consultadas a qualquer momento.
  - O local de publicação é definido pela AC ou o Certificado Digital possui um campo com apontador para o endereço web respectivo (campo extensões).
  - A periodicidade de publicação é definida pela AC.
  - Tipicamente, de hora em hora, mas há casos em que são atualizadas 1 vez ao dia.

Processo de revogação

- Outro meio: protocolo OCSP *(Online Certificate Status Protocol)*.
  - Consulta status de um certificado via web.
  - Transmitidas via HTTP *(request/response)*.



Dúvidas?

- Acesse os canais de comunicação da disciplina.



Referências

- STALLINGS, William; BARRETO, Paulo Sérgio Licciardi Messeder; MISOCZKI, Rafael. **Criptografia e segurança de redes**: princípios e práticas. 6.ed. São Paulo: Pearson Education do Brasil, 2015.
- UNIVESP. Segurança da Informação - Aula 04 - Algoritmos assimétricos e certificação digital. 2018. (23m08s). Disponível em <https://www.youtube.com/watch?v=4xv0RD8T1qA>. Acesso em: 31 mar. 2021.
- MAZIERO, Carlos. Capítulo 4 – Assinaturas e certificados. 2019. Disponível em < http://wiki.inf.ufpr.br/maziero/lib/exe/fetch.php?media=sc:seg-texto-04.pdf>. Acesso em 10 mar. 2024.